



ICT RISK ASSESSMENT · UNIVERSITY OF PISA

A Rule-Based Phishing Email Risk Analyzer

Explainable risk scoring from header, link and language signals

Ahmed Zarrad Master's in Artificial Intelligence and Data Engineering

LOW

MEDIUM

HIGH

CRITICAL



The Problem: Phishing

Phishing impersonates a trusted entity to steal credentials, deliver malicious links, or authorise fraud. It is one of the most common ways an attacker first gets in.

The risk-assessment challenge:

- Score how risky an email is, with evidence, and
- almost never flag a legitimate message.

Three things phishing leaves behind



Sender impersonation

A forged or brand-faking sender, e.g. a bank emailing from a Gmail address.



Deceptive links

Look-alike domains and links whose text hides their real destination.



Social-engineering wording

Manufactured urgency, account threats and credential lures.



Approach: Rule-Based and Explainable

Why rule-based, not machine learning?



Fully transparent

Every point of the score is an explicit, human-readable rule.



No training data or model

Pure Python standard library; runs anywhere, easy to grade.



Explicit risk indicators

The reasons an email is risky are stated, not hidden in weights.

Trade-off accepted by design: weaker on entirely novel patterns.

Three independent angles



Header analysis

SPF / DKIM / DMARC and sender spoofing



Link analysis

Look-alike domains and deceptive links

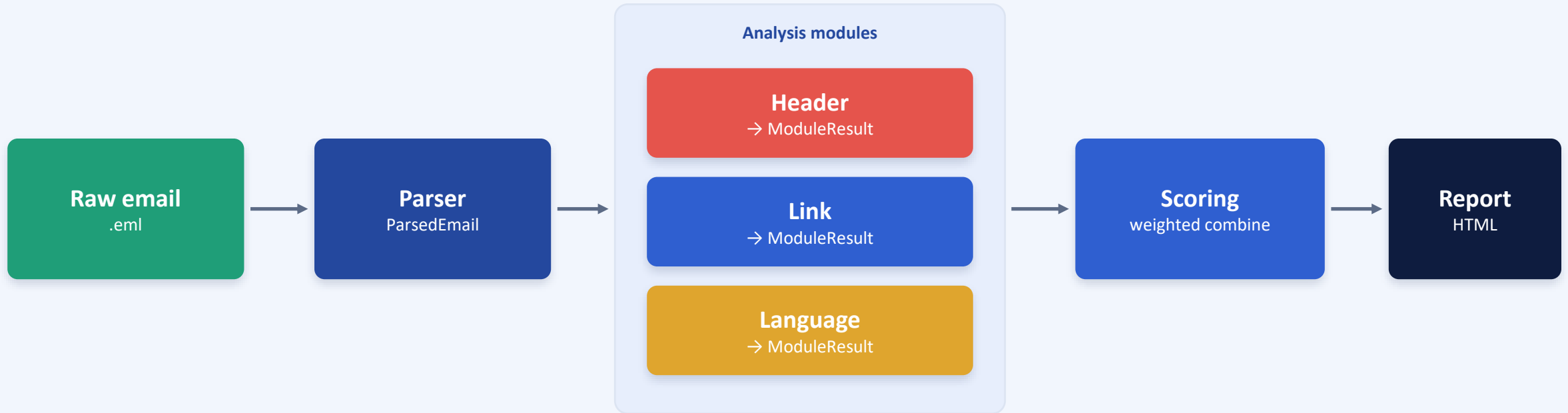


Language analysis

Urgency, threats and credential lures



System Architecture



Each module returns a uniform 0 to 100 score plus explainable findings, so the combiner and report treat all three angles identically.



Module 1: Header Analysis



Authentication

Did SPF, DKIM and DMARC actually pass? Read from the Authentication-Results header.



Identity alignment

Do the From, Return-Path, Reply-To and DKIM signing domains all agree?



Sender sanity

Empty or forged From, brand impersonation, or an org name sent from free webmail.



The key fairness rule

Missing SPF / DKIM / DMARC adds zero points. Only authentication that is present and failing scores.

The legitimate corpus predates email authentication, so penalising its absence would flag every old email.

A real bank never emails customers from a gmail.com address. An organisational display name on free webmail is a strong tell (multilingual).



Module 2: Link Analysis



Look-alike (typosquatted) domains

Edit distance plus homoglyph folding: paypa1.com, amaz0n.com.



Brand misuse (combosquatting)

A brand planted in an attacker-owned domain: paypal-security.com.



Deceptive destinations

Raw-IP hosts, the user@host trick, and punycode homographs.



Link text hides the target

Visible text shows a trusted brand, the link opens somewhere else.

Guarded against false alarms

- Minimum brand-name length: short names alias to noise (msnbc $\approx$ hsbc), so they are skipped.
- Brand-misuse only fires inside the registered domain, not on legitimate product subdomains.
- Link-text mismatch only for known brands, since generic redirects are common in real newsletters.



Module 3: Language Analysis



Coercion categories

Urgency, account threats, credential lures, sensitive-info and reward bait.



Phrases, not keywords

"verify your account" is specific; bare "password" appears in normal mail.



Multilingual

English plus Portuguese, Spanish and German, matching the corpus.



Synergy bonus

Stacking several tactics at once is the hallmark of phishing.

Why phrases matter

Legitimate technical mail is full of words like "password", "verify" and "click" used innocently.

Multi-word phrases and per-category caps keep ordinary mail low, while the foreign-language terms add detection at no false-positive cost on the English control set.



Combining the Signals

$$\text{overall} = 0.85 \times \text{peak} + 0.50 \times \text{weighted average} \quad (\text{clamped } 0 \text{ to } 100)$$

Peak gives sensitivity to one decisive signal; the average rewards corroboration and keeps legitimate mail low.

Module weights

Header		0.40
Link		0.35
Language		0.25

Risk bands

Low	0 to 24
Medium	25 to 49
High	50 to 74
Critical	75 to 100



Datasets



Phishing Pot

8,608

Real phishing emails with full headers. The positive class.



SpamAssassin ham

2,750

Legitimate emails (easy_ham + hard_ham). The control set.

The legitimate corpus predates SPF / DKIM / DMARC, exactly the property that drives the fairness rules.



Results

67.1%

Detection (recall)

0.44%

False-positive rate

99.8%

Precision

80.2%

F1 score

Confusion matrix (flag at medium or above)

	pred phishing	pred legit
actual phishing	5,773 TP	2,835 FN
actual legit	12 FP	2,738 TN

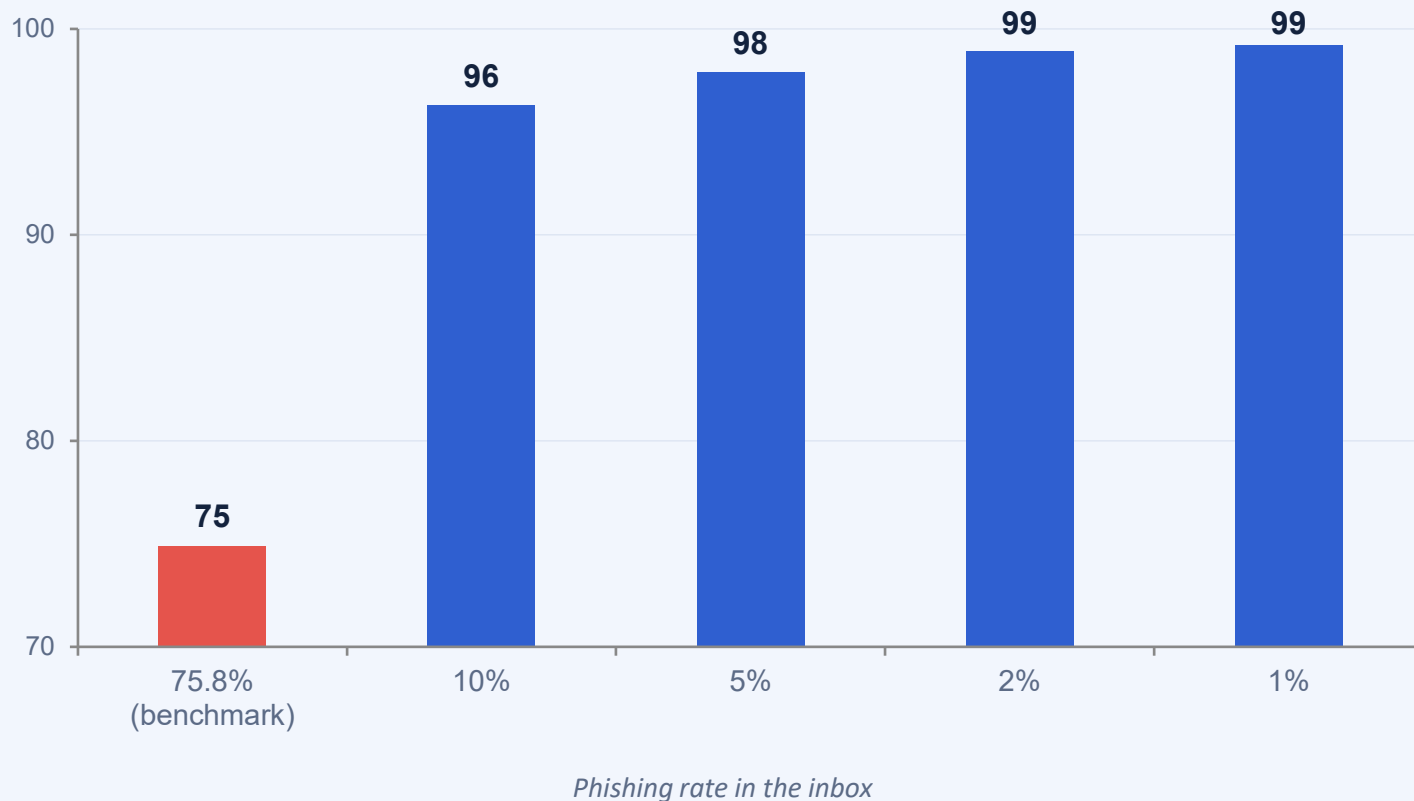
**When it flags an email,
it is right 99.8% of the time.**

Errors are 99.6% missed phishing, not false alarms on good mail.



On Accuracy: Reading It Correctly

Accuracy is 74.9%, but that is misleading. 99.6% of the errors are missed phishing (not false alarms), and the test set is an artificial 75.8% phishing.



Same detector, realistic inbox

- Real inboxes are mostly legitimate mail (5 to 10% phishing).
- At those rates the same tool scores 96 to 99% accuracy.
- False positives stay at the real 12 / 2,750.



Keeping False Positives Near Zero

0.44%

false-positive rate

12 of 2,750 legitimate
emails flagged

From over 4% → 0.44%

*each false positive traced to a root cause and fixed at
the source*

The fairness constraints



Absent SPF / DKIM / DMARC scores 0, and only present-and-failing checks add risk.



Return-Path / Reply-To mismatches suppressed for mailing-list and bulk mail.



Look-alike matching ignores short-brand edit-distance noise (msnbc ≈ hsbc).



Brand-misuse restricted to the attacker-owned registered domain label.



Link-text mismatch restricted to known brands (not generic tracking redirects).



Limitations (Honest)

What it misses

- Phishing from genuinely compromised, fully authenticated accounts.
- Payloads hidden in attachments or images, with no scoreable text.
- About one third of phishing at the medium threshold: the weak-signal cases.

How it could be evaded

Pass authentication from a real account, use a brand-new domain that is not a look-alike, and avoid coercive wording.



By design

A rule-based engine cannot cover patterns it has no rule for. That is the cost of full transparency.

It is meant as one explainable triage layer inside a defence-in-depth pipeline, not the only defence.



Conclusion

- A complete, explainable, rule-based phishing risk analyzer scoring three angles into one calibrated rating.
- 67% detection at a 0.44% false-positive rate and 99.8% precision; 96 to 99% accuracy on a realistic inbox.
- *Quality is measured less by how aggressively it flags than by how rarely it wrongs legitimate mail.*